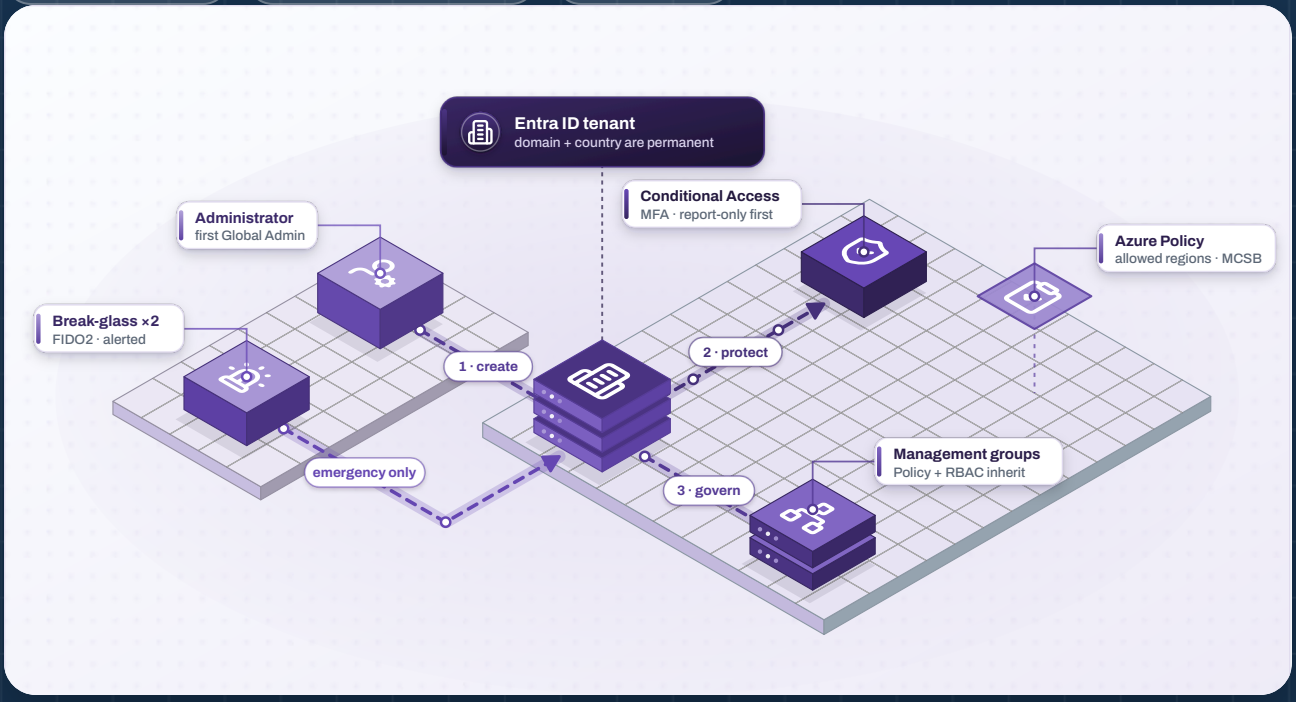
STANDARD OPERATING PROCEDURE · FIELD GUIDE SERIES

SOP-AZ-001

Creating and Securing a Microsoft Azure Tenant

Tenant creation in the portal, then a security and governance baseline applied four ways: portal, a Graph + Az PowerShell template, Azure CLI / Bicep, and configuration-as-code.

Microsoft Azure | Identity & Governance | Compliance



DOCUMENT ID	SOP-AZ-001
VERSION	2.0
EFFECTIVE	October 2026
AUDIENCE	Cloud administrators, IAM engineers, security and compliance leads
AUTHOR	Richmond Dieujuste, Principal Consultant

Rich Dieu IT Solutions LLC · richdieu.com

Sanitized reference edition — client identifiers removed

Contents

1. Concepts You Need First 3

1.1 Tenant, subscription, management group, resource group 3

1.2 Microsoft Entra ID and its two role systems 4

1.3 Permanent decisions: initial domain and country/region 4

1.4 Break-glass (emergency access) accounts 6

1.5 Security defaults versus Conditional Access 7

1.6 Custom domains and DNS verification 7

1.7 Management groups and Azure Policy 8

1.8 Choosing a method 8

2. Access, Prerequisites and Planning 10

2.1 Level of access required 10

2.2 Prerequisites checklist 11

3. Method A · Portal: Create the Tenant and Apply the Baseline 13

4. Methods B–D · Scripting the Baseline 18

4.1 Method B · PowerShell base template 18

4.2 Method C · Azure CLI and Bicep 21

4.3 Method D · Configuration-as-code with Microsoft365DSC 22

5. Verification, Evidence and Troubleshooting 23

5.1 Verification checklist 23

5.2 Monitoring the break-glass accounts 23

5.3 Compliance mapping 24

5.4 Evidence to retain 25

5.5 Rollback by stage 25

5.6 Troubleshooting 26

6. Summary, Glossary and Review 27

6.1 Summary 27

6.2 Glossary 27

LEARNING OBJECTIVES

After working through this procedure you will be able to:

- Explain the difference between a tenant, a billing account, a subscription, a management group and a resource group, and how Microsoft Entra ID fits over all of them.
- Identify which tenant settings are permanent (initial domain, country/region) and what the country choice does and does not control for data residency.
- Create a workforce tenant in the portal and immediately protect it with two break-glass accounts and an exclusion group.
- Choose between security defaults and Conditional Access, and deploy a baseline MFA policy safely in report-only mode first.
- Verify a custom domain with a DNS TXT record and build a management-group hierarchy with Azure Policy assignments.
- Apply the least-privilege Entra and Azure RBAC roles for each task and produce audit evidence mapped to SOC 2, ISO 27001, NIST 800-53, HIPAA and PCI DSS.

TIME	DIFFICULTY	MINIMUM ROLE	RISK
≈ 2 hours (plus DNS propagation)	Intermediate	Global Administrator for first setup only, then delegated roles	High: permanent choices + lock-out risk

CHAPTER 1

Concepts You Need First

Every Microsoft cloud deployment starts with one object that most people never see directly: the **tenant**. Virtual machines, storage accounts, Microsoft 365 mailboxes, Intune-managed laptops and every administrator who touches them all belong to exactly one tenant. Get the tenant right and every later control has a solid foundation. Get it wrong and some mistakes are permanent: the only fix is to build a new tenant and migrate everything into it.

> **KEY CONCEPT · THE TENANT IS THE BUILDING, NOT THE FURNITURE**
>
> Think of a tenant as an office building your organization leases from Microsoft. The building has one front desk (Microsoft Entra ID) that issues every badge, a street address that can never change (the initial `.onmicrosoft.com` domain), and it stands in one country (the country/region you pick on day one). Subscriptions are the floors you rent inside the building, each with its own utility meter. Resource groups are the rooms, and resources are the furniture. You can rearrange furniture and even move floors to another building, but you cannot pick the building up and move it to another street.

1.1 Tenant, subscription, management group, resource group

These four words are often used loosely. In an audit, using them precisely is the difference between "we have a control" and "we can show you the control".

Object	What it is	Key facts
Tenant	A dedicated, isolated instance of **Microsoft Entra ID** (formerly Azure Active Directory). It holds users, groups, app registrations, directory roles and authentication policy. Identified by a *tenant ID* (a GUID) and its domains.	Trusted by many subscriptions; shared with Microsoft 365 and Intune.
Billing account	The commercial agreement (Enterprise Agreement, Microsoft Customer Agreement, CSP partner or Pay-As-You-Go) that receives the invoice.	Creating a tenant creates no billing.
Subscription	A billing and quota boundary for Azure resources, linked to one billing account and trusting one tenant for sign-in.	Common unit for prod / non-prod separation.
Management group	A container *above* subscriptions. Azure Policy and RBAC assigned to a management group are inherited by every subscription inside it.	Up to six levels under the *Tenant Root Group*.

Resource group	A logical folder inside a subscription that groups resources sharing a lifecycle (for example everything for one application).	Can hold resources from any region.

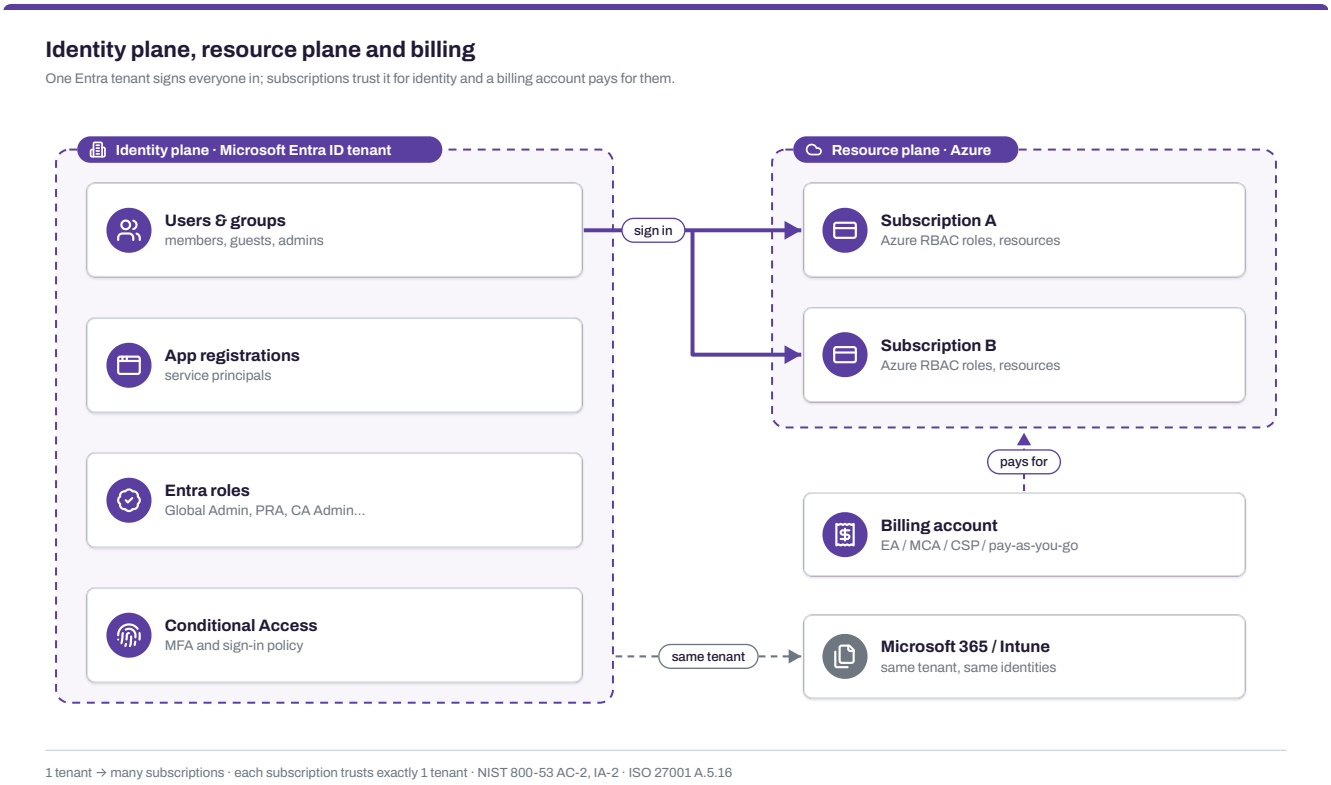


Figure 1. Because identity lives in the tenant and not in any subscription, deleting or moving a subscription never deletes the people who can sign in to it.

1.2 Microsoft Entra ID and its two role systems

Entra ID answers two questions for every request: *who are you* (authentication) and *what may you do* (authorization). **Microsoft Entra roles** (Global Administrator, Privileged Role Administrator, Conditional Access Administrator…) control the *directory*. **Azure RBAC roles** (Owner, Contributor, Management Group Contributor…) control *Azure resources* at management-group, subscription, resource-group or resource scope. A Global Administrator has no Azure resource rights by default, but can grant themselves User Access Administrator over every subscription with the `Access management for Azure resources` switch, which must be used briefly and recorded (Chapter 3).

1.3 Permanent decisions: initial domain and country/region

The `Create a tenant` wizard asks for three values. Their permanence varies:

Field	Changeable?	Guidance
Organization name	YES	Display name only. Editable later in **Entra ID › Overview › Properties.**
Initial domain name	NEVER	Becomes `<name>.onmicrosoft.com`. It cannot be renamed or removed, and in Microsoft 365 it also appears in default SharePoint/OneDrive URLs. Pick a neutral, durable name (no project names, no "test").
Country / region	NEVER	Determines the geography where Microsoft stores the tenant's *directory* data (and, for Microsoft 365, where the default data location is). Changing it means building a new tenant.

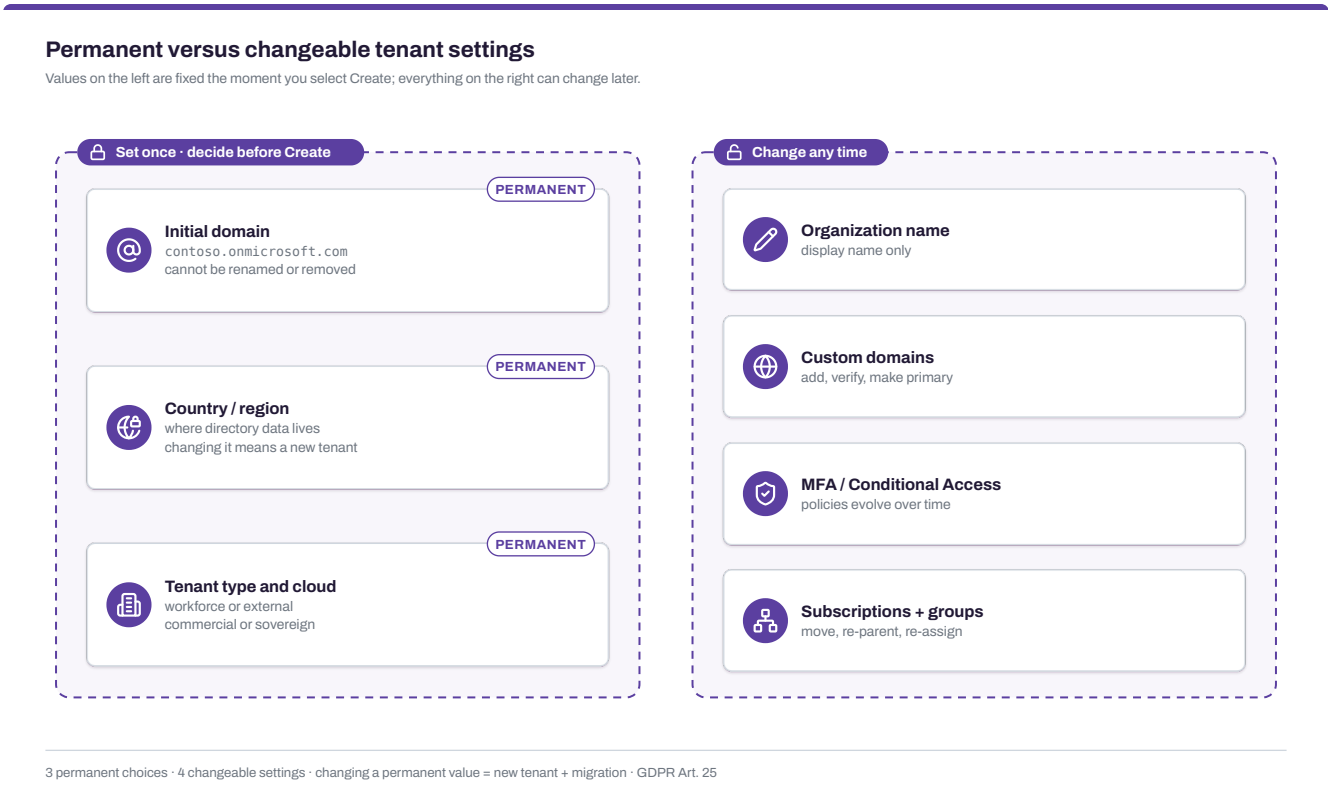


Figure 2. Settle the left-hand column before you select Create; everything on the right is safe to iterate on later.

What the country choice does and does not control

Data residency is the requirement that certain data be stored, and sometimes processed, only inside a defined geography (for example the European Union under GDPR, or a single country under a sovereignty law). Two different settings govern it:

- The tenant **country/region** governs where *identity* data lives: user objects, group memberships, sign-in logs. Selecting an EU country places the directory in Microsoft's EU datacenters and within the EU Data Boundary commitments.

- The Azure **region** you choose for each resource governs where *workload* data lives. A tenant created in Germany can still deploy a VM to East US unless you stop it. That is why this SOP adds an *Allowed locations* Azure Policy at the management-group level (Chapter 3); SOP-AZ-002 builds a VM under that policy.

Workloads that require Azure Government (FedRAMP High, ITAR, CJIS) must use a tenant created in that sovereign cloud (`portal.azure.us`); a commercial tenant cannot be converted, so decide this first.

1.4 Break-glass (emergency access) accounts

A break-glass account is a highly privileged, cloud-only account kept in reserve for the day normal administrative access fails: a Conditional Access policy locks everyone out, the federation server is down, or every admin's MFA device is lost. Microsoft's guidance is to keep **at least two**.

- Cloud-only, on the `.onmicrosoft.com` domain, so they work even if a custom domain or federation breaks.
- Permanently assigned Global Administrator (not PIM-eligible), not tied to any person, never used for daily work.
- Protected by **phishing-resistant MFA** (a FIDO2 key kept in a safe): Microsoft now enforces MFA for Azure portal and admin-center sign-ins, so password-only emergency accounts no longer work there.
- Excluded from Conditional Access policies through a dedicated, role-assignable group, and monitored: every sign-in raises an alert.

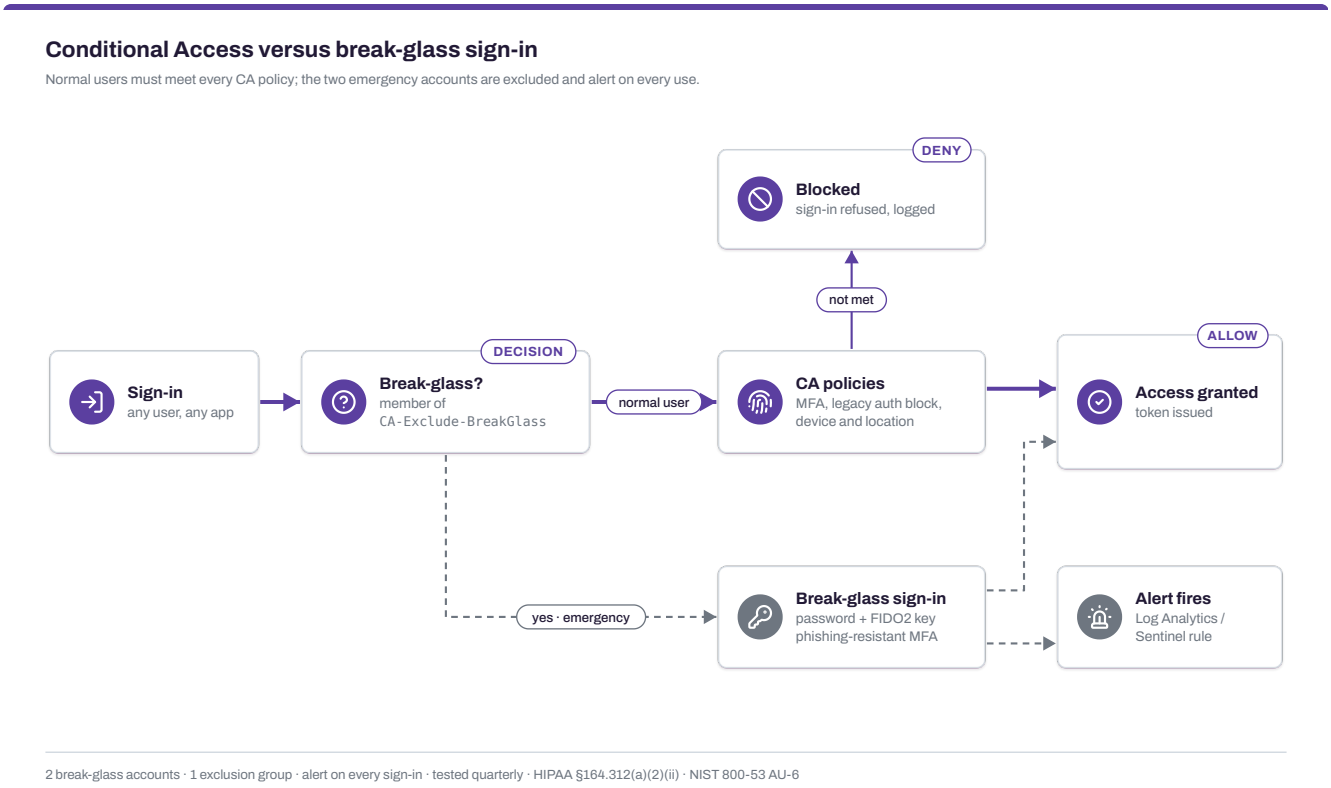


Figure 3. The break-glass exclusion is deliberate, narrow and loudly monitored, so it can never become a quiet way around MFA.

1.5 Security defaults versus Conditional Access

Security defaults

A single on/off switch, enabled automatically on new tenants. Requires all users to register for MFA, prompts admins for MFA on every sign-in, and blocks legacy authentication protocols. Free, no tuning, no exclusions.

Best for: very small tenants without Entra ID P1.

Conditional Access (CA)

If-then policies evaluated at every sign-in: *if* user X opens app Y from condition Z, *then* require MFA, a compliant device, or block. Supports exclusions (break-glass), report-only testing and named locations. Requires Entra ID P1 (included in Microsoft 365 E3/E5 and Business Premium).

Best for: every enterprise or regulated tenant.

The two are mutually exclusive: you must turn security defaults *off* before CA policies can be enabled. Do it in the right order, so there is never a window with no MFA at all: build CA policies in **report-only**, confirm the results in the sign-in logs, switch them on, and only then disable security defaults.

1.6 Custom domains and DNS verification

Users should sign in as `user@contoso.com`, not `…@contoso.onmicrosoft.com`. To add a domain you prove control of its public DNS: Entra issues a unique TXT value (`MS=ms` + digits), you

publish it at the apex, and Entra looks it up when you select `Verify`. Entra never touches your registrar, and a domain can be verified in only one tenant at a time.

1.7 Management groups and Azure Policy

Azure Policy evaluates every resource create or update request against rules such as "only these regions" or "every resource must have an Owner tag", and then denies, audits, appends or remediates. Assign policies at a management group and every current and future subscription beneath it inherits them. An *initiative* (policy set) bundles many policies; the **Microsoft cloud security benchmark** initiative is the default compliance baseline in Defender for Cloud. The figure below shows the starter hierarchy this SOP builds, modelled on the Azure landing-zone pattern: policies at `mg-contoso` apply to every subscription, and workload-specific rules sit lower down.

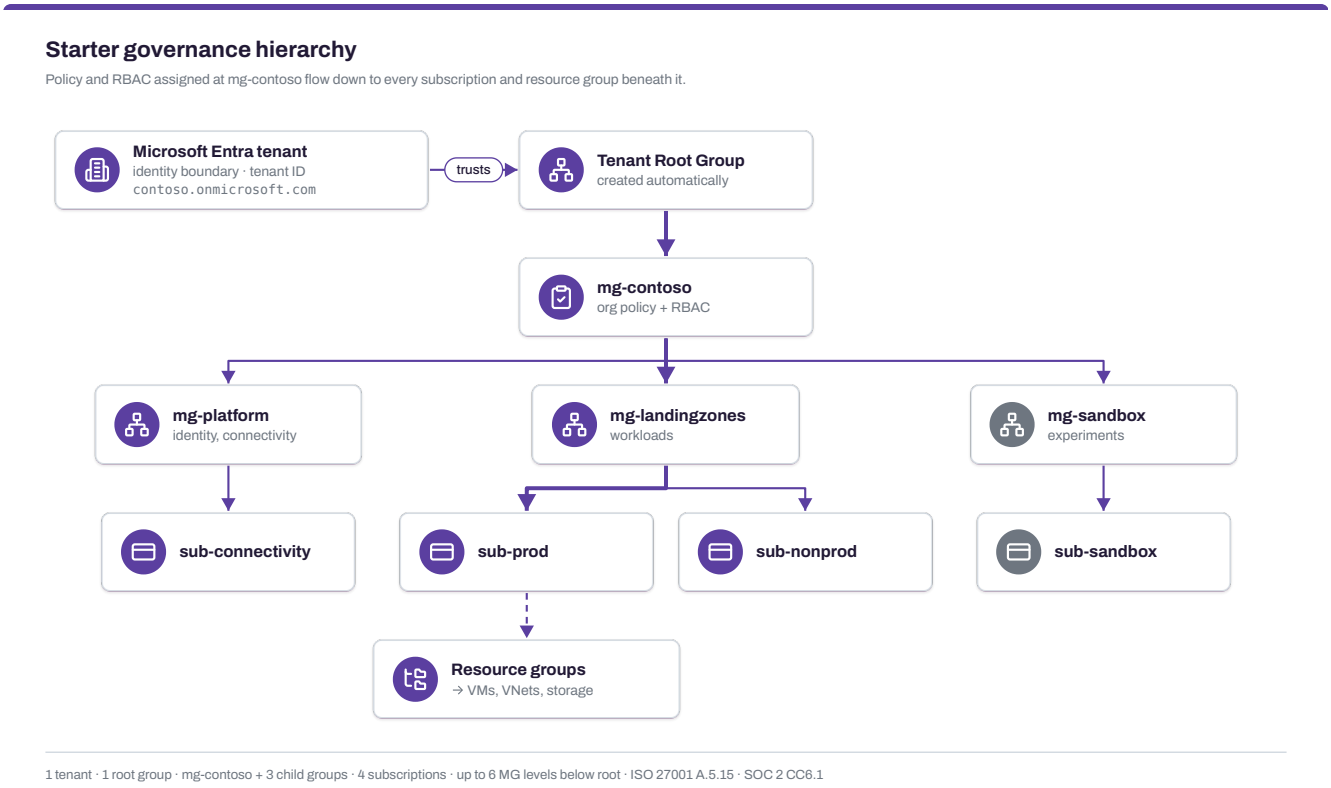


Figure 4. Assign policy and RBAC as high as it is true, and every subscription created next year inherits it without anyone remembering to.

1.8 Choosing a method

Creating the tenant itself is a one-time, interactive action. Microsoft does not provide a supported PowerShell cmdlet or CLI command that creates a workforce tenant; it is done in the Entra admin center or Azure portal (or implicitly when an organization signs up for Microsoft 365 or Azure). Everything *after* creation can and should be scripted.

A · Portal

Create the tenant, then apply the baseline by hand in the Entra admin center and Azure portal.

BEST FOR: THE FIRST TENANT, LEARNING

B · PowerShell baseline

Microsoft Graph PowerShell for identity settings plus Az for management groups and policy, with -WhatIf and an evidence file.

BEST FOR: REPEATABLE, AUDITED SETUP

C · Azure CLI / Bicep

Management groups and policy assignments as code, deployable from a pipeline.

BEST FOR: GOVERNANCE-AS-CODE TEAMS

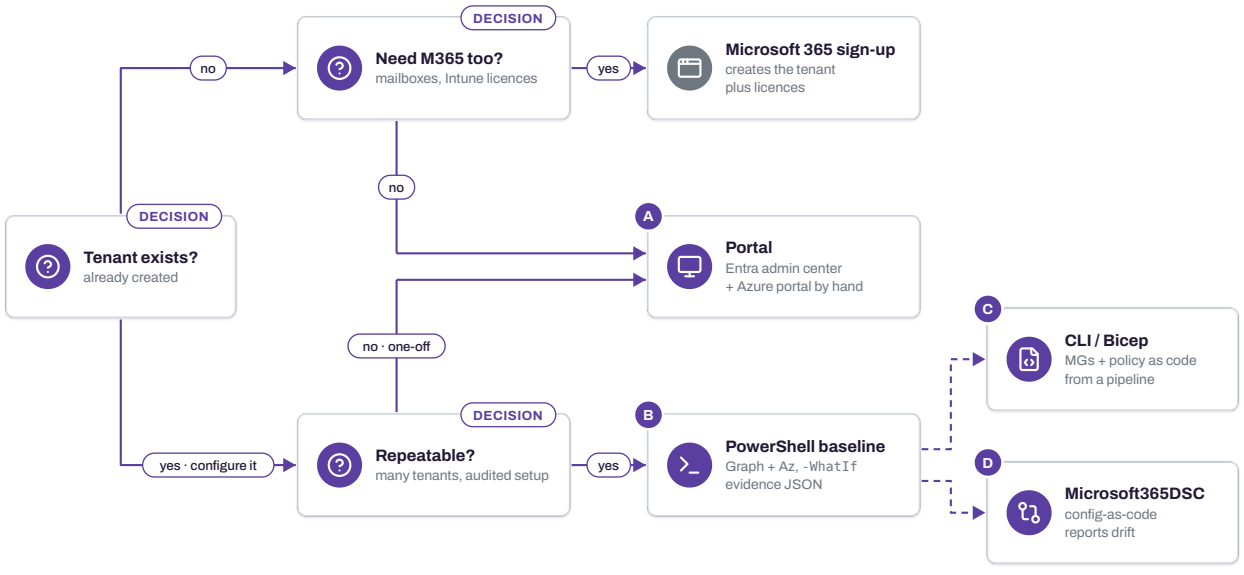
D · Configuration-as-code

Microsoft365DSC exports and enforces Entra settings (CA, groups, roles) and reports drift.

BEST FOR: MANY TENANTS, MSPS

Choosing how to create and baseline the tenant

Answer the questions left to right; the letters match the method chapters.



4 methods · A creates and baselines by hand · B–D apply the same baseline as code · Entra ID P1 for CA, P2 for PIM

Figure 5. Most teams build the first tenant by hand with Method A, then capture it as code with B, C or D once it must be repeated.

CHAPTER 2

Access, Prerequisites and Planning

2.1 Level of access required

The person who creates a tenant automatically becomes its first **Global Administrator**. That is necessary for the first hour and dangerous afterwards. The goal of this SOP is to use Global Administrator only to set up break-glass accounts and delegate everything else to narrower roles, ideally made *eligible* through Privileged Identity Management (PIM).

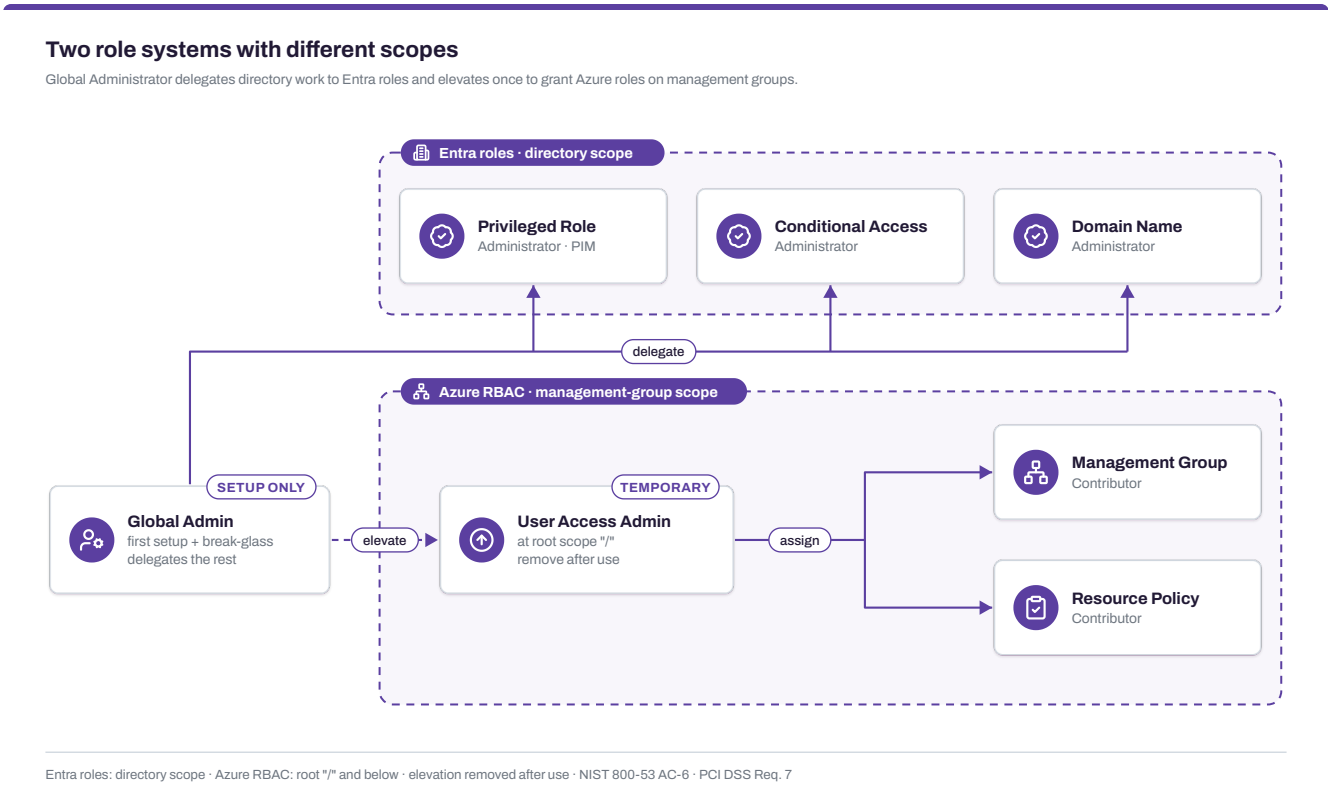


Figure 6. Global Administrator is for setup and emergencies only; day-to-day work belongs to the narrow roles it delegates.

Task	Least-privilege role (scope)	Notes
Create the tenant	Any signed-in work or Microsoft account	Blocked if the source tenant enables `Restrict non-admin users from creating tenants` (Entra › Users › User settings). Creator becomes Global Administrator.
Create break-glass users and the exclusion group	Global Administrator (tenant)	Assigning Global Administrator requires Global Administrator or Privileged Role Administrator.

Assign directory roles, configure PIM	Privileged Role Administrator (tenant)	Manages role-assignable groups too. Graph scope `RoleManagement.ReadWrite.Directory`.
Security defaults, Conditional Access	Conditional Access Administrator or Security Administrator (tenant)	Graph scopes `Policy.ReadWrite.ConditionalAccess`, `Policy.ReadWrite.SecurityDefaults`, `Policy.Read.All`.
Add and verify custom domains	Domain Name Administrator (tenant)	Plus DNS-zone write access at the registrar or Azure DNS (DNS Zone Contributor). Graph scope `Domain.ReadWrite.All`.
Create / move management groups	Management Group Contributor (Tenant Root Group)	Moving a subscription also needs Owner on the subscription and MG Contributor on the old and new parent.
Assign Azure Policy	Resource Policy Contributor (management group)	Policies with *deployIfNotExists*/*modify* also need Role Based Access Control Administrator to grant the remediation identity its role.
First-time root access	Global Administrator + Access management for Azure resources	Grants User Access Administrator at `/`. Use it once to assign the roles above, then switch it off.

GOOD PRACTICE · JUST-IN-TIME PRIVILEGE

With Entra ID P2, make every role above (except break-glass) *eligible* in PIM with MFA, justification and a few-hour maximum. Give auditors read-only Security Reader + Reader.

RISK · LOCK-OUT

The highest-impact failure in this SOP is a Conditional Access policy that blocks every administrator. It is prevented by three habits: break-glass accounts exist and are excluded *before* any CA policy is created, every policy starts in report-only mode, and you keep a second signed-in admin session open while enabling a policy.

2.2 Prerequisites checklist

- ☐ Approved change record (e.g. `CHG0012345`) for the evidence file.
- ☐ Decided values: organization name, initial domain prefix (check availability), country/region, commercial versus sovereign cloud, allowed Azure regions, and one production tenant (extra tenants only for true isolation).
- ☐ Two FIDO2 keys and a safe for break-glass credentials; DNS write access.

- [ ] Licensing (Entra ID P1 for CA, P2 for PIM); for Method B, PowerShell 7 with `Microsoft.Graph` and `Az`.

CHAPTER 3

Method A · Portal: Create the Tenant and Apply the Baseline

The portal path is the only way to create the tenant itself, so even script-first teams perform Stage 1 here. Portal labels change from time to time; the paths below use the Microsoft Entra admin center (entra.microsoft.com), with Azure portal equivalents where useful.

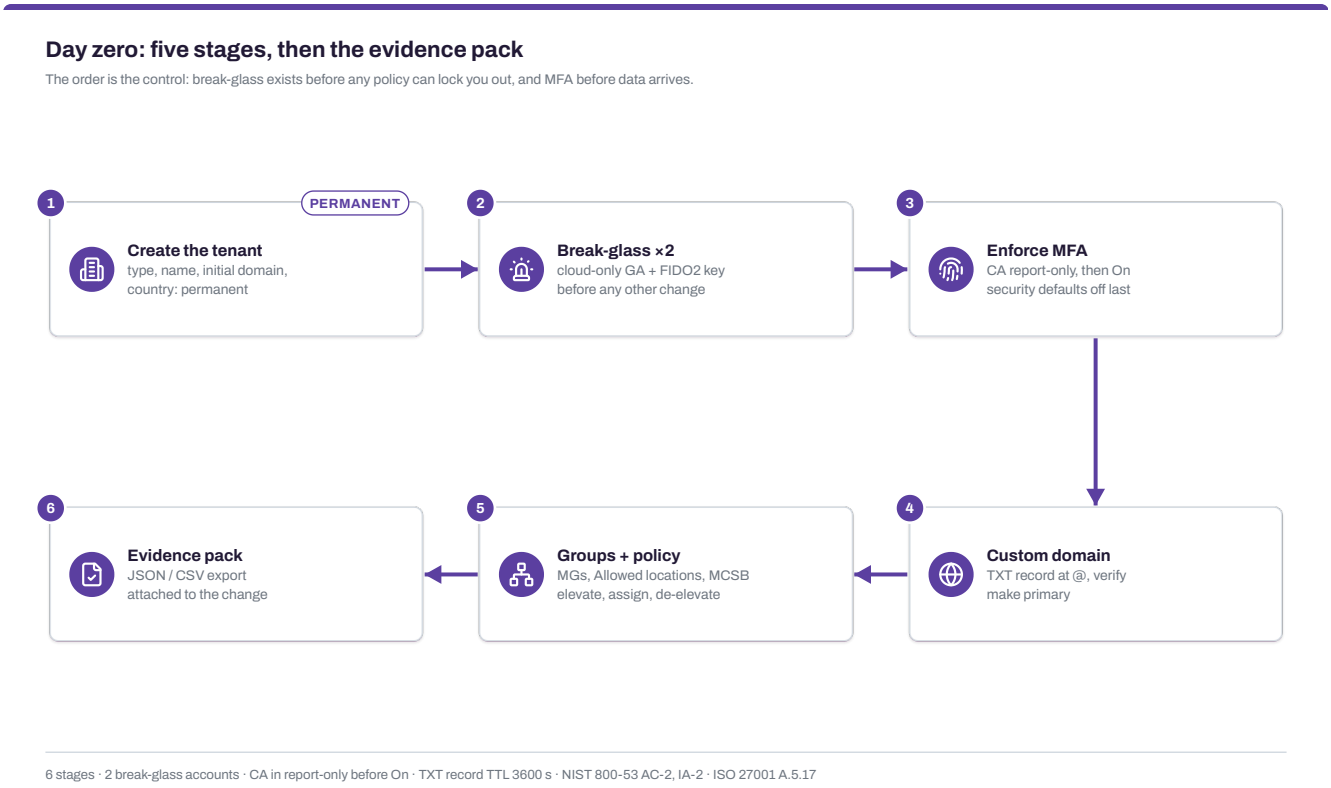


Figure 7. Never reorder these stages: each one protects the tenant against a mistake in the next.

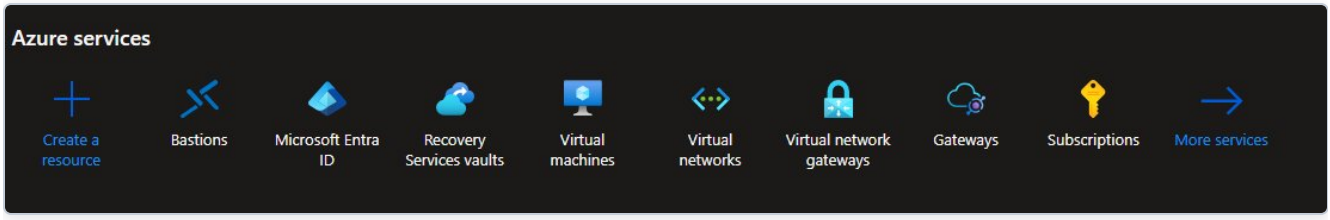


Figure 8. The Azure services bar on the portal home page. Microsoft Entra ID and Subscriptions are the two services this SOP uses most.

STAGE 1 Create the tenant

1. Open an InPrivate window and sign in to **entra.microsoft.com** (or **portal.azure.com**) with the account that will become the first Global Administrator.
2. Go to **Entra ID › Overview › Manage tenants** and select **+ Create**. In the Azure portal the same page is **Microsoft Entra ID › Manage tenants**; you can also reach it from the account menu via **Switch directory**.
3. Choose the **workforce** tenant type (*Microsoft Entra ID*). The other option creates an *external* tenant for customer identities (Entra External ID, formerly Azure AD B2C) and cannot be converted later.
4. On **Configuration**, enter **Organization name**, **Initial domain name** (the wizard checks availability) and **Country/Region**. Re-read the last two: they are permanent.
5. Select **Review + create**, complete the human-verification challenge, then **Create**. Provisioning usually completes within a few minutes.
6. Switch to the new tenant (**Switch directory**) and record the **Tenant ID** and primary domain from **Entra ID › Overview** in the change record.

> **NOTE · YOUR ACCOUNT IN THE NEW TENANT**
>
> The creating account is added to the new tenant with Global Administrator, but it remains homed in its original directory. Create native cloud admin accounts in the new tenant (next stage) so the tenant never depends on another organization's directory.

STAGE 2 Break-glass accounts and exclusion group

1. **Entra ID › Users › All users › + New user › Create new user**. UPN `bg-admin-01@contoso.onmicrosoft.com`, display name *Emergency Access 01*, auto-generate a long password, set **Account enabled**. Repeat for `bg-admin-02`.
2. On each account, **Assigned roles › + Add assignments** › *Global Administrator*, assignment type **Active** and **Permanent**.
3. **Entra ID › Groups › + New group**: Security group `CA-Exclude-BreakGlass`, **Microsoft Entra roles can be assigned to the group** = **Yes** (this protects membership:

only Privileged Role Administrators and Global Administrators can change it). Add both accounts.

4. Sign in once with each account, register a FIDO2 key (**mysignins.microsoft.com › Security info**), then seal the password and key in separate locations. Record who holds them.
5. When a Log Analytics workspace exists, add an alert on any sign-in by either account (Chapter 5).

STAGE 3 Enforce MFA: security defaults or Conditional Access

Option 1, no P1 licence: confirm **Entra ID › Overview › Properties › Manage security defaults** shows *Enabled*. Stop here for this stage.

Option 2, P1 or higher (recommended):

1. **Entra ID › Conditional Access › Policies › + New policy**. Name `CA001-Require-MFA-All-Users`.
2. **Users**: Include *All users*, exclude `CA-Exclude-BreakGlass`. **Target resources**: *All resources*.
3. **Grant**: *Grant access › Require multifactor authentication* (or, better, *Require authentication strength › Phishing-resistant MFA* for an admin-roles policy).
4. **Enable policy**: **Report-only**. Create a second policy `CA002-Block-Legacy-Auth` (client apps: Exchange ActiveSync + Other clients; Grant: Block), also report-only.
5. After a few days, review **Sign-in logs › Report-only** results. Switch both policies to **On**, verify a test sign-in, then set security defaults to **Disabled**.

STAGE 4 Add and verify the custom domain

1. **Entra ID › Domain names › + Add custom domain** (in older layouts: *Settings › Domain names*). Enter `contoso.com` › **Add domain**.
2. Copy the TXT record: host `@`, value `MS=ms########`, TTL 3600.
3. Create the record at the DNS host. Check it is public with `nslookup -type=TXT contoso.com 8.8.8.8`.
4. Back in Entra select **Verify**. If it fails, wait for propagation (usually minutes, at most the old TTL) and retry.

5. Optionally **Make primary** so new users default to `@contoso.com`. The TXT record can stay; it is harmless and helps if re-verification is ever needed.

STAGE 5 Management groups, policy and subscriptions

1. Temporarily elevate: **Entra ID › Overview › Properties › Access management for Azure resources = Yes** › **Save**. Sign out and back in.
2. In the Azure portal open **Management groups**. On first use Azure creates the *Tenant Root Group*. Select **+ Create** for `mg-contoso` under the root, then `mg-platform`, `mg-landingzones` (with children `mg-prod` and `mg-nonprod` if wanted) and `mg-sandbox`.
3. On the Tenant Root Group, **Access control (IAM) › + Add role assignment**: grant *Management Group Contributor* and *Resource Policy Contributor* to a platform-admins group (eligible in PIM). Then set the elevation switch back to **No**.
4. In **Management groups › Settings**, enable **Require write permissions for creating new management groups** and choose a default management group (for example `mg-sandbox`) so new subscriptions do not land directly under the root.
5. **Policy › Assignments › Assign initiative**, scope `mg-contoso`: *Microsoft cloud security benchmark* (audit). Then **Assign policy**: *Allowed locations* and *Allowed locations for resource groups* with your approved regions, effect Deny.
6. Create a subscription (**Subscriptions › + Add**) in the new tenant, or move an existing one with **Subscription › Overview › Change directory**. Then place it under the right management group.

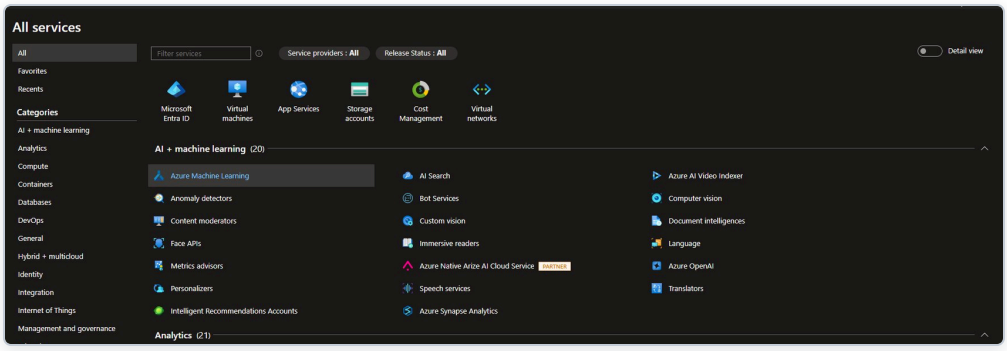


Figure 9. The All services catalog. *Management and governance* (left) contains Management groups and Policy; *Identity* leads to Microsoft Entra ID.

WATCH OUT · CHANGING A SUBSCRIPTION'S DIRECTORY

Moving a subscription to the new tenant **deletes all its Azure RBAC role assignments** and breaks system-assigned managed identities, Key Vault access policies tied to the old tenant ID and custom role definitions. Inventory them first (`Get-AzRoleAssignment`) and plan to recreate them.

CHAPTER 4

Methods B–D · Scripting the Baseline

4.1 Method B · PowerShell base template

Once the tenant exists, its baseline is configuration, and configuration belongs in a reviewed script. The template below uses two modules: **Microsoft Graph PowerShell** (`Microsoft.Graph`) for Entra settings and **Az** for management groups and Azure Policy. It is idempotent where practical (it looks for objects before creating them), supports `-WhatIf`, creates every CA policy in report-only mode, and writes a JSON evidence file.

> **NOTE · WHAT THE SCRIPT CANNOT DO**
>
> It does not create the tenant (no supported API exists for workforce tenants), register FIDO2 keys (that requires the person holding the key), or create the DNS record at your registrar (unless you add Azure DNS cmdlets). Those steps stay manual and are listed in the output.

SET-TENANTBASELINE.PS1 · BASE TEMPLATE — POWERSHELL

```powershell
<#
.SYNOPSIS  Apply a security + governance baseline to a NEW Microsoft Entra tenant.
.NOTES     PowerShell 7+.  Install-Module Microsoft.Graph, Az -Scope CurrentUser
           Run as Global Administrator (first run) with Azure root access elevated for Stage 5.
           Everything is created in a safe state: CA policies are REPORT-ONLY.
#>
[CmdletBinding(SupportsShouldProcess)]
param(
  [Parameter(Mandatory)] [string]   $TenantId,
  [Parameter(Mandatory)] [string]   $InitialDomain,           # contoso.onmicrosoft.com
  [Parameter(Mandatory)] [string]   $ChangeRef,               # CHG0012345
  [string]   $CustomDomain      = '',                         # contoso.com (blank = skip)
  [string]   $OrgMgName         = 'mg-contoso',
  [string[]] $AllowedLocations  = @('germanywestcentral','westeurope'),
  [string]   $UsageLocation     = 'DE',
  [switch]   $DisableSecurityDefaults                         # only after CA is validated
)
$ErrorActionPreference = 'Stop'
$evidence = [ordered]@{ ChangeRef = $ChangeRef; TenantId = $TenantId; StartedUtc = (Get-
Date).ToUniversalTime() }

# ---- Stage 0: connect ------------------------------------------------------------
Connect-MgGraph -TenantId $TenantId -NoWelcome -Scopes @(
  'User.ReadWrite.All','Group.ReadWrite.All','RoleManagement.ReadWrite.Directory',
  'Policy.Read.All','Policy.ReadWrite.ConditionalAccess','Policy.ReadWrite.SecurityDefaults',
  'Domain.ReadWrite.All','Organization.Read.All')
Connect-AzAccount -Tenant $TenantId | Out-Null
$evidence.Operator = (Get-MgContext).Account
$evidence.Organization = (Get-MgOrganization | Select-Object DisplayName, CountryLetterCode, Id)

# ---- Stage 1: break-glass accounts -----------------------------------------------
$gaRoleId = '62e90394-69f5-4237-9190-012177145e10'          # Global Administrator (template ID)
$bgUsers = foreach ($n in 1..2) {
```

```
  $upn = "bg-admin-0$n@$InitialDomain"
  $u = Get-MgUser -Filter "userPrincipalName eq '$upn'" -ErrorAction SilentlyContinue
  if (-not $u -and $PSCmdlet.ShouldProcess($upn, 'Create break-glass user')) {
    $pw = -join ((33..126) | Get-Random -Count 32 | ForEach-Object { [char]$_ })   # hand to custodian,
never log
    $u = New-MgUser -DisplayName "Emergency Access 0$n" -UserPrincipalName $upn -MailNickname "bg-admin-
0$n" `
           -AccountEnabled -UsageLocation $UsageLocation `
           -PasswordProfile @{ Password = $pw; ForceChangePasswordNextSignIn = $false }
    Write-Host "Password for $upn shown ONCE - seal it now: $pw" -ForegroundColor Yellow
  }
  $u
}

# ---- Stage 2: role-assignable exclusion group + permanent GA ----------------------
$grp = Get-MgGroup -Filter "displayName eq 'CA-Exclude-BreakGlass'" -ErrorAction SilentlyContinue
if (-not $grp -and $PSCmdlet.ShouldProcess('CA-Exclude-BreakGlass', 'Create group')) {
  $grp = New-MgGroup -DisplayName 'CA-Exclude-BreakGlass' -MailEnabled:$false -MailNickname 'ca-exclude-
bg' `
           -SecurityEnabled -IsAssignableToRole:$true -Description 'Emergency access accounts. Excluded
from all CA.'
}
foreach ($u in $bgUsers | Where-Object { $_ }) {
  if ($PSCmdlet.ShouldProcess($u.UserPrincipalName, 'Add to exclusion group + assign Global
Administrator')) {
    New-MgGroupMember -GroupId $grp.Id -DirectoryObjectId $u.Id -ErrorAction SilentlyContinue
    $has = Get-MgRoleManagementDirectoryRoleAssignment -Filter "principalId eq '$($u.Id)' and
roleDefinitionId eq '$gaRoleId'"
    if (-not $has) {
      New-MgRoleManagementDirectoryRoleAssignment -PrincipalId $u.Id -RoleDefinitionId $gaRoleId -
DirectoryScopeId '/' | Out-Null
    }
  }
}
$evidence.BreakGlass = $bgUsers.UserPrincipalName; $evidence.ExclusionGroupId = $grp.Id

# ---- Stage 3: Conditional Access baseline (REPORT-ONLY) ---------------------------
$policies = @(
  @{ displayName = 'CA001-Require-MFA-All-Users'; state = 'enabledForReportingButNotEnforced'
     conditions  = @{ users = @{ includeUsers = @('All'); excludeGroups = @($grp.Id) }
                      applications = @{ includeApplications = @('All') }; clientAppTypes = @('all') }
     grantControls = @{ operator = 'OR'; builtInControls = @('mfa') } },
  @{ displayName = 'CA002-Block-Legacy-Auth'; state = 'enabledForReportingButNotEnforced'
     conditions  = @{ users = @{ includeUsers = @('All'); excludeGroups = @($grp.Id) }
                      applications = @{ includeApplications = @('All') }
                      clientAppTypes = @('exchangeActiveSync','other') }
     grantControls = @{ operator = 'OR'; builtInControls = @('block') } }
)
$existing = Get-MgIdentityConditionalAccessPolicy -All
foreach ($p in $policies) {
  if ($existing.DisplayName -notcontains $p.displayName -and $PSCmdlet.ShouldProcess($p.displayName,
'Create CA policy (report-only)')) {
    New-MgIdentityConditionalAccessPolicy -BodyParameter $p | Out-Null
  }
}
$sd = Get-MgPolicyIdentitySecurityDefaultEnforcementPolicy
if ($DisableSecurityDefaults -and $sd.IsEnabled -and $PSCmdlet.ShouldProcess('Security defaults',
'Disable')) {
  Update-MgPolicyIdentitySecurityDefaultEnforcementPolicy -IsEnabled:$false   # only after CA is switched
ON
}
$evidence.SecurityDefaultsEnabled = (Get-MgPolicyIdentitySecurityDefaultEnforcementPolicy).IsEnabled
```

```
$evidence.CaPolicies = Get-MgIdentityConditionalAccessPolicy -All | Select-Object DisplayName, State

# ---- Stage 4: custom domain ------------------------------------------------
if ($CustomDomain) {
  $d = Get-MgDomain -DomainId $CustomDomain -ErrorAction SilentlyContinue
  if (-not $d -and $PSCmdlet.ShouldProcess($CustomDomain, 'Add domain')) { $d = New-MgDomain -Id
$CustomDomain }
  if ($d -and -not $d.IsVerified) {
    $txt = Get-MgDomainVerificationDnsRecord -DomainId $CustomDomain | Where-Object RecordType -eq 'Txt'
    Write-Host "Create TXT @ = $($txt.AdditionalProperties.text)  then re-run to verify." -
ForegroundColor Cyan
    try { Confirm-MgDomain -DomainId $CustomDomain | Out-Null } catch { Write-Warning 'Not verified yet
(DNS).' }
  }
  $evidence.CustomDomain = Get-MgDomain -DomainId $CustomDomain | Select-Object Id, IsVerified, IsDefault
}

# ---- Stage 5: management groups + Azure Policy (Az) ------------------------------
$rootId = "/providers/Microsoft.Management/managementGroups/$TenantId"
$tree = @{ $OrgMgName = $rootId; 'mg-platform' = $OrgMgName; 'mg-landingzones' = $OrgMgName; 'mg-sandbox'
= $OrgMgName }
foreach ($mg in @($OrgMgName, 'mg-platform', 'mg-landingzones', 'mg-sandbox')) {     # parents first
  $parent = if ($tree[$mg] -like '/providers/*') { $tree[$mg] } else {
"/providers/Microsoft.Management/managementGroups/$($tree[$mg])" }
  if (-not (Get-AzManagementGroup -GroupName $mg -ErrorAction SilentlyContinue) -and
      $PSCmdlet.ShouldProcess($mg, "Create management group under $parent")) {
    New-AzManagementGroup -GroupName $mg -DisplayName $mg -ParentId $parent | Out-Null
  }
}
$scope = "/providers/Microsoft.Management/managementGroups/$OrgMgName"
$allowed = Get-AzPolicyDefinition -Id '/providers/Microsoft.Authorization/policyDefinitions/e56962a6-
4747-49cd-b67b-bf8b01975c4c'
$mcsb    = Get-AzPolicySetDefinition -Builtin | Where-Object {
             ($_.DisplayName, $_.Properties.DisplayName) -contains 'Microsoft cloud security benchmark' }
| Select-Object -First 1
if ($PSCmdlet.ShouldProcess($scope, 'Assign Allowed locations + MCSB')) {
  New-AzPolicyAssignment -Name 'allowed-locations' -DisplayName 'Allowed locations' -Scope $scope `
    -PolicyDefinition $allowed -PolicyParameterObject @{ listOfAllowedLocations = $AllowedLocations } |
Out-Null
  New-AzPolicyAssignment -Name 'mcsb' -DisplayName 'Microsoft cloud security benchmark' -Scope $scope `
    -PolicySetDefinition $mcsb | Out-Null
}
$evidence.ManagementGroups = (Get-AzManagementGroup).Name
$evidence.PolicyAssignments = Get-AzPolicyAssignment -Scope $scope | ForEach-Object { $_.Name }

# ---- Evidence --------------------------------------------------------------------
$evidence.FinishedUtc = (Get-Date).ToUniversalTime()
$evidence.ManualFollowUps = @('Register FIDO2 keys for both break-glass accounts',
  'Review report-only CA results, then set policies to On', 'Turn OFF Access management for Azure
resources')
$evidence | ConvertTo-Json -Depth 6 | Out-File ".\$ChangeRef-tenant-baseline.json"
Write-Host "Baseline applied. Evidence: .\$ChangeRef-tenant-baseline.json" -ForegroundColor Green
```

EXAMPLE · RUNNING THE TEMPLATE

INVOCATION POWERSHELL

```powershell
.\Set-TenantBaseline.ps1 -TenantId '<tenant-guid>' -InitialDomain 'contoso.onmicrosoft.com' `
  -CustomDomain 'contoso.com' -ChangeRef 'CHG0012345' -AllowedLocations
germanywestcentral,westeurope -WhatIf
# Review the "What if" lines, then run again without -WhatIf.
# Days later, after report-only review and enabling CA:  ... -DisableSecurityDefaults
```

KEY CONCEPT · DELEGATED SCOPES ARE A PERMISSION REQUEST, NOT A PERMISSION

`Connect-MgGraph -Scopes` asks for delegated permissions on behalf of the signed-in user. The script can only do what *both* the consented scopes and the user's directory role allow. A Conditional Access Administrator with every scope above still cannot assign Global Administrator, which is exactly the least-privilege behaviour you want.

TIP · UNATTENDED RUNS

For a pipeline, replace interactive sign-in with an app registration that uses a certificate (`Connect-MgGraph -ClientId -CertificateThumbprint -TenantId`) and grant the matching *application* permissions with admin consent. Keep that app's permissions as narrow as the table in Chapter 2 and store the certificate in Key Vault.

4.2 Method C · Azure CLI and Bicep

The Azure CLI manages management groups and policy well, which makes it a good fit for Bash-based pipelines. Identity settings (users, CA) are better left to Graph (Method B) or Microsoft365DSC (Method D).

GOVERNANCE.SH BASH

```bash
TENANT=<tenant-guid>
az login --tenant $TENANT
az account management-group create --name mg-contoso --display-name "Contoso" --parent $TENANT
for mg in mg-platform mg-landingzones mg-sandbox; do
  az account management-group create --name $mg --display-name $mg --parent mg-contoso
done
az account management-group subscription add --name mg-landingzones --subscription <sub-guid>

# Allowed locations (Deny) at the org management group
az policy assignment create --name allowed-locations --display-name "Allowed locations" \
  --scope /providers/Microsoft.Management/managementGroups/mg-contoso \
  --policy e56962a6-4747-49cd-b67b-bf8b01975c4c \
  --params '{"listOfAllowedLocations":{"value":["germanywestcentral","westeurope"]}}'
```

Bicep describes the desired state; Azure Resource Manager works out what to create. Management groups are tenant-scope resources, so this file is deployed with `az deployment`

`tenant create`, which requires rights at the root scope (a first-run elevation, or a platform identity granted Owner at the Tenant Root Group).

GOVERNANCE.BICEP TEXT

```
targetScope = 'tenant'
param children array = [ 'mg-platform', 'mg-landingzones', 'mg-sandbox' ]

resource org 'Microsoft.Management/managementGroups@2023-04-01' = {
  name: 'mg-contoso'
  properties: { displayName: 'Contoso' }       // parent defaults to the Tenant Root Group
}
resource kids 'Microsoft.Management/managementGroups@2023-04-01' = [for c in children: {
  name: c
  properties: { displayName: c, details: { parent: { id: org.id } } }
}]
// Deploy:  az deployment tenant create --location germanywestcentral --template-file governance.bicep --
what-if
// Policy assignments go in a second file with targetScope = 'managementGroup'
// (resource type Microsoft.Authorization/policyAssignments), deployed with az deployment mg create.
```

TIP · DO NOT START FROM SCRATCH

For larger estates, Microsoft publishes the **Azure Landing Zones** reference implementation (Bicep and Terraform accelerators) which builds a complete management-group hierarchy, policy set and connectivity. This SOP's hierarchy is a deliberately small subset you can grow into that model.

4.3 Method D · Configuration-as-code with Microsoft365DSC

Microsoft365DSC is an open-source PowerShell Desired State Configuration module, supported by Microsoft engineers, that can *export* a tenant's Entra, Intune, Exchange and Teams settings to code and *enforce* or *report drift* against that code. For identity baselines it covers resources such as Conditional Access policies, groups, role settings and authentication-method policies.

Typical workflow: build and validate a reference tenant with Method A or B; export it with `Export-M365DSCConfiguration -Components @('AADConditionalAccessPolicy','AADGroup','AADRoleSetting')` using certificate-based app authentication; store the configuration in source control with tenant-specific values parameterized; then apply it to new tenants or run `Test-M365DSCConfiguration` on a schedule to report drift.

This is the method of choice for managed-service providers and organizations operating several tenants. It complements, not replaces, Azure Policy for the resource plane.

CHAPTER 5

Verification, Evidence and Troubleshooting

5.1 Verification checklist

Identity plane

- ☐ Tenant ID, initial domain and country recorded in the change record
- ☐ Two break-glass accounts, Active + Permanent Global Administrator, FIDO2 registered
- ☐ Exclusion group is role-assignable and contains only the two accounts
- ☐ CA policies On (or security defaults Enabled); never both off
- ☐ Test user is prompted for MFA; legacy-auth sign-in is blocked
- ☐ Custom domain shows *Verified*
- ☐ Global Administrator count is between 2 and 4 (excluding break-glass where possible)

Resource plane

- ☐ Hierarchy visible under Tenant Root Group
- ☐ Default management group set; write permission required for new MGs
- ☐ Allowed-locations assignment denies a test deployment in a non-approved region
- ☐ MCSB initiative shows a compliance score in Defender for Cloud
- ☐ Access management for Azure resources set back to **No**
- ☐ Subscriptions placed under the correct management groups

QUICK VERIFICATION — POWERSHELL

```
Get-MgOrganization | Select-Object DisplayName, CountryLetterCode, Id
Get-MgPolicyIdentitySecurityDefaultEnforcementPolicy | Select-Object IsEnabled
Get-MgIdentityConditionalAccessPolicy -All | Select-Object DisplayName, State
Get-MgDirectoryRoleMember -DirectoryRoleId (Get-MgDirectoryRole -Filter "displayName eq 'Global
Administrator'").Id |
  ForEach-Object { $_.AdditionalProperties.userPrincipalName }
# Policy test - should fail with RequestDisallowedByPolicy:
New-AzResourceGroup -Name rg-policy-test -Location eastus -WhatIf
```

5.2 Monitoring the break-glass accounts

Send Entra sign-in and audit logs to a Log Analytics workspace (**Entra ID › Monitoring & health › Diagnostic settings**), then create an Azure Monitor alert (or a Microsoft Sentinel analytics rule) on this query, firing on any result:

BREAK-GLASS SIGN-IN ALERT — KQL

```
SigninLogs
| where UserPrincipalName in~ ("bg-admin-01@contoso.onmicrosoft.com", "bg-admin-
02@contoso.onmicrosoft.com")
```

```
| project TimeGenerated, UserPrincipalName, IPAddress, AppDisplayName, ResultType,
ConditionalAccessStatus
```

Test both accounts on a schedule (for example quarterly): sign in, confirm the alert fired, and record the test.

5.3 Compliance mapping

Auditors examine the tenant first because it defines identity, authentication and audit logging. The steps in this SOP *support* these controls; written policy, reviews and operating evidence are still required.

Framework	Control	How this SOP supports it
SOC 2	CC6.1 Logical access; CC6.2 provisioning	Single identity boundary, least-privilege role delegation, PIM activation history, MFA via CA.
ISO/IEC 27001:2022	A.5.15 Access control; A.5.16 Identity management; A.5.17 Authentication information; A.8.5 Secure authentication	Named roles per task, verified domain identities, break-glass custody procedure, phishing-resistant MFA.
NIST SP 800-53 Rev. 5	AC-2 Account management; AC-6 Least privilege; IA-2 Identification and authentication; AU-6 Audit review	Documented account types (admin, emergency), MFA for privileged users, alerting on emergency-account use.
HIPAA Security Rule	§164.312(a)(2)(ii) Emergency access procedure; §164.312(d) Person or entity authentication	Break-glass accounts with custody and testing; MFA enforced for all users.
PCI DSS v4.0	Req. 7 Restrict access; Req. 8 Identify users and authenticate (8.4 MFA)	Role-based access, MFA for all administrative access into the cardholder data environment.
GDPR	Art. 25 Data protection by design; Art. 32 Security of processing	EU country/region for directory data, Allowed-locations policy keeping workload data in approved regions.

5.4 Evidence to retain

Keep with the change record: the Method B evidence JSON; a screenshot or export of **Entra ID › Overview › Properties**; the Global Administrator assignment list and PIM history; an export of the CA policies with their report-only results; the domain list showing *Verified*; and the management-group and policy-assignment listing with the Defender for Cloud regulatory compliance report.

5.5 Rollback by stage

Stage	Rollback action
Tenant created with wrong domain or country	No in-place fix. If nothing depends on it yet, delete it: remove all users except the deleting admin, apps, subscriptions and licences, then **Manage tenants › Delete**. Create a new tenant with the correct values.
Break-glass accounts	Never roll back to fewer than two. Replace a compromised account by creating a new one before deleting the old.
Conditional Access	Set the policy to *Off* or *Report-only*. If locked out, sign in with a break-glass account first.
Security defaults	Re-enable only after turning off all CA policies (they cannot coexist).
Custom domain	Remove references (UPNs, proxy addresses, app URIs) then delete the domain; remove the TXT record.
Management groups / policy	Delete the policy assignment first, move subscriptions back to the parent, then delete empty management groups bottom-up.

5.6 Troubleshooting

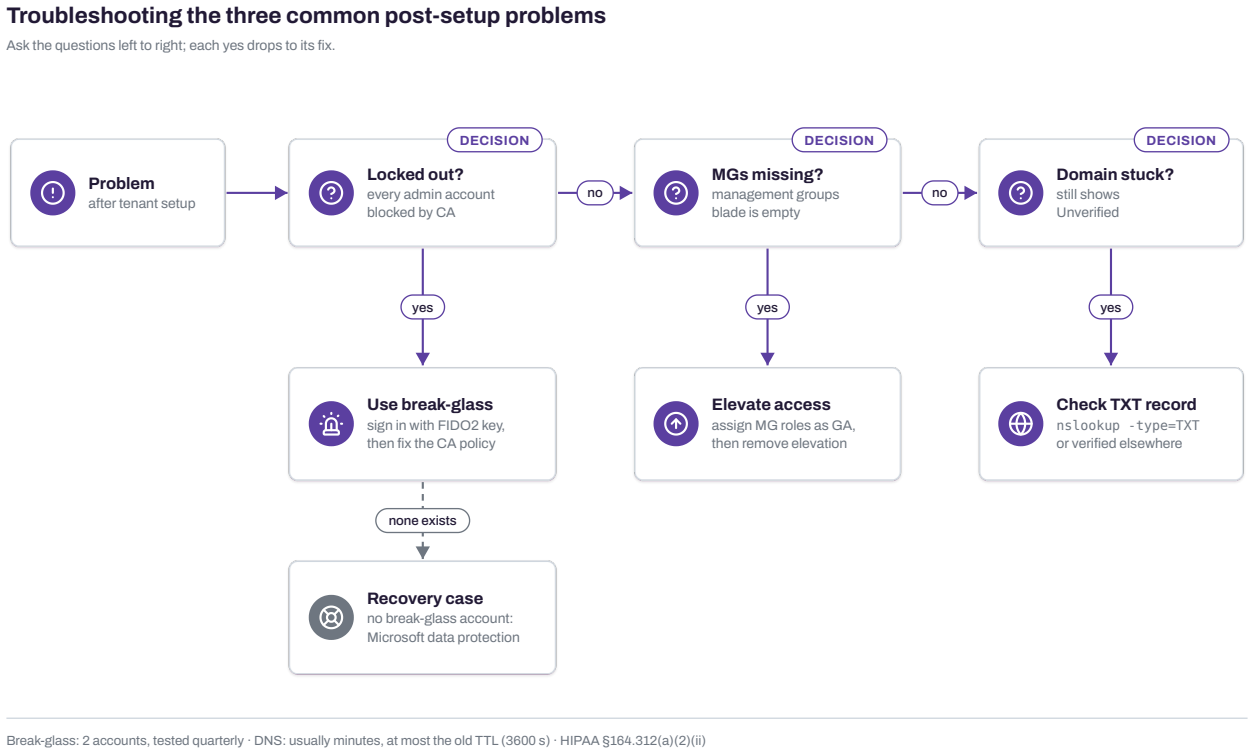


Figure 10. Most post-setup tickets are one of these three, and two of them are fixed with access you already prepared on day zero.

Symptom	Likely cause and fix
Create **under Manage tenants is greyed out**	The source tenant restricts tenant creation by non-admins. Ask its administrator, or start from a fresh account.
Domain verification fails	TXT record created on a subdomain instead of the apex (`@`), not yet propagated, or the domain is already verified in another tenant (remove it there first).
Management groups blade is empty or *Create* fails with AuthorizationFailed	No Azure RBAC at root. Elevate access, assign Management Group Contributor at Tenant Root Group, sign out and in, then remove elevation.
Policy assignment succeeds but resources are still created in other regions	Assignment at the wrong scope, effect set to Audit, or the subscription is not under that management group. Check `Get-AzPolicyAssignment -Scope`.
Admins locked out by a CA policy	Sign in with a break-glass account, set the policy to report-only, and review the sign-in log's CA tab to find the rule that blocked them.

CHAPTER 6

Summary, Glossary and Review

6.1 Summary

- A tenant is the Entra ID identity boundary; subscriptions, billing and management groups hang off it but are separate objects.
- The initial `.onmicrosoft.com` domain and the country/region are permanent. Country governs directory data; Azure regions (enforced by policy) govern workload data.
- Protect the tenant before using it: two monitored break-glass accounts, an exclusion group, and MFA via security defaults or report-only-first Conditional Access.
- Verify the custom domain by DNS TXT, put Allowed-locations and benchmark policy at the top management group, create the tenant in the portal and script everything afterwards with Graph + Az PowerShell, CLI/Bicep or Microsoft365DSC, and keep the evidence.

6.2 Glossary

Tenant	Dedicated instance of Microsoft Entra ID representing one organization.
Break-glass account	Cloud-only emergency Global Administrator, excluded from CA and monitored.
Conditional Access	Entra ID P1 policy engine that grants, challenges or blocks sign-ins (report-only mode logs without enforcing).
PIM	Privileged Identity Management; eligible, time-bound role activation.

Check your understanding

1. A US-country tenant must now keep EU customer data in the EU. What can Azure Policy fix, and what can never change?
2. Why do break-glass accounts use `.onmicrosoft.com` and a role-assignable exclusion group?
3. What is the safe order for moving from security defaults to Conditional Access?
4. Which roles does someone need who only verifies domains and assigns policy at a management group?
5. Why can't Method B create the tenant, and which baseline steps still need a person?